

LAB4 – IASEC

Leendert F. Parreño BSCS3B

PART 1

1. Scope

In-scope

- Three web applications
- Internal network consisting of 50 servers
- Mobile Banking App
- 200 employee workstations

Out-of-scope

- Third party systems
- Customer owned devices

Justification:

They are excluded because they are not owned by Nexus Financial Service. The out-of-scope requires separate authorizations from the other third parties.

Authorized Testing Methods

Web applications

- Authorized: Input validation testing, Authentication testing, session management testing
- Precautions: Authenticated vulnerability scanning
- Test environment only: SQL injection exploitation, Business logic testing

Internal Network

- Authorized: Static analysis
- Precautions: Dynamic analysis
- Test environment only: Exploitation of vulnerabilities, server testing

Mobile app

- Authorized: Sport scanning, service enumeration
- Precautions: Authenticated vulnerability scanning
- Test environment only: Exploitation of vulnerabilities, API exploitation

Workstations

- Authorized: Authentication testing, Application analysis
- Precautions: Phishing attack simulation
- Test environment only: Malware simulation, DOS testing

Engagement Timeline

Phase	Day	What Happens
Kickoff & Planning	Day 1	Sign RoE, receive credentials, set up VPN access.
Reconnaissance	Days 2–3	Passive OSINT, asset discovery, attack surface mapping.
Scanning & Enumeration	Days 4–6	Nmap, Nessus, Nikto, MobSF static analysis, LDAP/SMB checks.
Exploitation	Days 7–10	Manual exploitation of confirmed vulnerabilities.
Post-Exploitation	Days 11–12	Lateral movement and privilege escalation within authorized areas.
Reporting	Days 13–15	Write up findings, risk ratings, recommendations; present to client.

Emergency Contact

Role	Name	Phone	Email
IT Security Manager	[Name]	[+63 0123456789]	[email@nexusbank.ph]
Developer	[Name]	[+63 0123456789]	[email@nexusbank.ph]
Testing Lead	[Name]	[+63 0123456789]	[email@student.edu.ph]

Data Handling

- All data such as screenshots, logs, and credentials must be stored in an encrypted folder accessible only to the team lead.
- No real customer PII or financial data may be taken out of client systems. If accidentally captured, delete immediately and report it.
- All engagement data must be securely deleted within 30 days after the report is submitted.

Legal Analysis Table

Law	Lawful within scope	Criminal without authorization
RA 10175	Running a port scan on the system servers within the agreed scope	The same port scan without a signed RoE is illegal access, punishable under Philippine law
CFAA	Accessing a database containing US client records to test for data exposure vulnerabilities	The same database access without written authorization is a federal crime in the US
GDPR	Reviewing EU client records to verify that encryption and access controls are properly implemented	Accessing the same records without authorization is unlawful processing of personal data under EU law
PDPA	Retrieving customer PII from Nexus systems to verify it is properly encrypted and access-controlled	The same retrieval without consent or written authorization violates RA 10173 and carries criminal penalties

Emergency Stop Procedure

Conditions Triggering Halt

Stop testing if:

- Data corruption or system instability is detected
- Unauthorized access beyond scope occurs
- Sensitive customer data is exposed or leaked
- Active data exfiltration by an unknown third party is discovered

Notification Step

1. Stop all testing activities immediately
2. Contact the primary client
3. Follow up with an email to all emergency contacts
4. Wait for written approval before resuming

Documentation Requirements

- Document what happened
- Document the last action taken
- Preserve all logs, screenshots, and tool outputs

Ethical Dilemma Case Study Analysis

Case 1: Finding a Vulnerability Outside Scope

Factual Summary: The team finds a critical vulnerability in an out-of-scope third-party payment gateway during testing.

Legal Analysis : Exploiting it without authorization violates RA 10175, CFAA, PDPA, and GDPR regardless of intent.

Ethical Analysis — (ISC)² Canons

- Canon I: Report it to protect customers without testing further.
- Canon II: Exploiting it or staying silent are both wrong.
- Canon III: Report through proper channels so Nexus can notify the vendor.
- Canon IV: Crossing scope boundaries damages trust in the profession.

Case 2: Found Credentials That Open Out-of-Scope Systems

Factual Summary: The team finds plaintext admin credentials in an exposed file that would grant access to the out-of-scope core banking system.

Legal Analysis: Using those credentials to log in is still unauthorized access under RA 10175, CFAA, PDPA, and GDPR.

Ethical Analysis — (ISC)² Canons

- Canon I: Accessing the CBS risks every customer's privacy.
- Canon II: Report the impact without actually using the credentials.
- Canon III: A clear report serves the client better than an unauthorized breach.
- Canon IV: Crossing scope even when possible undermines the profession.

Case 3: Teammate Wants to Go Beyond Scope

Factual Summary: A teammate suggests exploiting a privilege escalation vulnerability to gain access to out-of-scope banking servers.

Legal Analysis: Accessing out-of-scope systems through lateral movement is illegal under RA 10175 and breaches the engagement contract.

Ethical Analysis — (ISC)² Canons

- Canon I: It creates real risk to banking infrastructure and customers.
- Canon II: "They'd thank us later" is just a rationalization to cross the boundary.
- Canon III: Deliver only what was contracted.
- Canon IV: Exceeding scope makes clients stop authorizing tests

Reflection

The principle I consider most important based on from this module is protecting sensitive information, because in today's digital world every information is already on the internet which makes it very important to secure. Having an authorization helps secure these sensitive information because it prevents you from accessing or editing information even if you can.

This is not only applicable in banking systems but also in other platforms. If that sensitive information is accessed by an attacker, it can be used for other illegal activities which could affect the credibility of that system or certain platforms.

This also came up in every part of the course. Legally it is what separates a penetration tester from a criminal under RA 10175, CFAA, and GDPR. Without proper authorization, even a simple port scan or accessing a database can already be considered a crime. That is why before any testing begins, a signed Rules of Engagement document is required.

In all three case studies, the dilemma was always the same. The tester had the technical ability to go further but doing so without authorization would already be a violation. In Case 1 the vulnerability was real but the system was out of scope. In Case 3 the argument sounded reasonable but it was still beyond what was agreed.

I also think this applies beyond penetration testing. In any security role the question of whether you are authorized to do something should always come first. Organizations trust security professionals with access to their most sensitive systems and that trust only works if you stay within what you were given. The real security also starts from us users, we can control what we share online and also the security of our sensitive information, By having a strong password we already help secure our own sensitive information.